

Proyecto Final de Ciberseguridad

Análisis de Incidente, **Pentesting** y Plan de Respuesta

• Servidor Debian comprometido •

• ANÁLISIS FORENSE • EXPLOTACIÓN CONTROLADA • CORRECCIÓN Y RESPUESTA ANTE INCIDENTES •

SARA MARTÍ – CS-PT-13



20 DE MAYO DE 2026

2 Contexto y fases del proyecto



Servidor Debian comprometido

Entorno vulnerable utilizado para analizar un incidente, realizar una explotación controlada y aplicar medidas de seguridad.

SERVICIOS RELEVANTES



SSH



FTP



Apache



WordPress



MariaDB



El proyecto se divide en tres fases:

1

Análisis del incidente

Revisión forense de evidencias con Autopsy sobre imagen .E01.



2

Pentesting controlado

Identificación y explotación de una nueva vulnerabilidad en entorno controlado.



3

Plan de respuesta a incidentes

Medidas de prevención, detección, respuesta y recuperación basadas en NIST.



Objetivo global: entender qué ocurrió, validar el impacto y reforzar la seguridad del servidor.

3 Fase 1: análisis del incidente



Objetivo

Reconstruir qué ocurrió en el servidor Debian comprometido e identificar evidencias, servicios afectados y configuraciones inseguras.



Metodología



Imagen forense .E01 creada con FTK Imager



Análisis en Autopsy



Revisión de logs, configuraciones y directorios web



Correlación de evidencias de SSH, FTP, Apache, WordPress y MariaDB



Secuencia observada

1

Cambios previos desde el usuario debian



2

Instalación y configuración de servicios remotos



3

Permisos inseguros en WordPress y Apache



4

Acceso SSH exitoso como root



Hipótesis principal: primero hubo una fase de preparación del entorno y después un acceso remoto con privilegios máximos.

4 Línea temporal del incidente



Secuencia del 8 de octubre

El análisis forense permitió reconstruir una secuencia de preparación del entorno seguida de un acceso remoto con privilegios máximos.

**16:08–16:10**

Instalación y configuración de vsftpd

16:12–16:14Instalación y configuración de SSH
PermitRootLogin yes · PasswordAuthentication yes**16:16–16:21**Permisos inseguros en WordPress y Apache
chmod 777 en /var/www/html y wp-config.php**16:49**

Acceso local a /wp-admin/ desde 127.0.0.1

17:40

Acceso SSH exitoso como root desde 192.168.0.134



Conclusión: primero hubo una fase de preparación del servidor y después un acceso remoto con privilegios máximos.

5 Hallazgos principales



Puntos críticos detectados

El análisis forense permitió identificar varias configuraciones inseguras y debilidades que facilitaron el compromiso del servidor.



1 SSH inseguro

PermitRootLogin yes y PasswordAuthentication yes



2 FTP expuesto

Servicio accesible y mayor superficie de ataque



3 Permisos inseguros en WordPress

chmod 777 en /var/www/html y wp-config.php



4 Apache permisivo

Require all granted e Indexes habilitado



5 MariaDB con privilegios excesivos

user@localhost con ALL PRIVILEGES y WITH GRANT OPTION



Conclusión: el incidente se apoyó en servicios expuestos, permisos excesivos y configuraciones inseguras.

6 Correcciones aplicadas en la fase 1



Medidas de mitigación

Tras el análisis del incidente, se aplicaron medidas de contención, hardening y cambio de credenciales para reducir la superficie de ataque del servidor.



1 SSH endurecido

PermitRootLogin no
PasswordAuthentication no
Fail2Ban configurado y
servicio deshabilitado



2 IP atacante bloqueada

Bloqueo con iptables de
la IP 192.168.0.134



3 Permisos de WordPress corregidos

755 en directorios
644 en archivos
640 en wp-config.php



4 Apache corregido

Require all denied
Options -Indexes
+FollowSymLinks



5 Credenciales renovadas

Cambio de contraseña de
debian, root, wordpressuser
y wordpress-user



6 MariaDB restringida

Revocación de privilegios a
user@localhost y cambio
de contraseña



Resultado: se corrigieron las configuraciones inseguras detectadas y se reforzó la protección del servidor frente a accesos no autorizados.



Objetivo del pentest

Comprobar el impacto de una nueva vulnerabilidad distinta al incidente inicial mediante una explotación controlada en el servidor Debian.



Proceso realizado

- 1. Reconocimiento y enumeración de servicios.
- 2. Identificación de FTP accesible.
- 3. Prueba controlada con Hydra sobre el usuario debian.
- 4. Acceso por FTP y revisión de archivos sensibles.

Cadena del pentest



1

FTP accesible

Superficie de ataque disponible.



2

Fuerza bruta controlada con Hydra

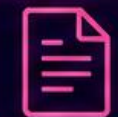
Credenciales válidas del usuario debian.



3

Acceso por FTP

Carga y descarga de archivos.



4

Descarga de wp-config.php

Obtención de credenciales de base de datos.



5

Riesgo identificado

Posible subida de archivo PHP malicioso o webshell.



Impacto: el pentest demostró que una mala configuración de FTP y el uso de credenciales débiles podían facilitar el acceso a archivos sensibles y la ejecución remota de código.

8 Impacto del pentest y mitigaciones



Impacto detectado

El pentest demostró que una mala configuración del FTP y el uso de credenciales débiles podían comprometer información sensible y facilitar nuevas fases del ataque.



Acceso no autorizado a archivos web

Lectura de archivos sensibles del servidor.



Exposición de credenciales

Obtención de credenciales desde wp-config.php.



Ejecución indebida de PHP

Riesgo de subida y ejecución de archivo PHP en el entorno web.



Riesgo de escalada

Reutilización de credenciales y ampliación del compromiso.



Conclusión: no bastaba con corregir SSH; también era necesario revisar otros servicios expuestos y reforzar la protección del entorno web.

Mitigaciones propuestas



1

Restringir o sustituir FTP por SFTP

Limitar el acceso o usar un protocolo más seguro.



2

Cambiar credenciales débiles

Contraseñas robustas, únicas y no reutilizadas.



3

Revisar permisos del entorno web

Proteger WordPress y wp-config.php.



4

Bloquear ejecución indebida de PHP

Especialmente en rutas de subida.



5

Reforzar la monitorización

Revisión de logs y alertas en servicios críticos.

9 Fase 3: plan de respuesta a incidentes



Enfoque del plan

Plan basado en NIST para organizar la prevención, detección, respuesta y recuperación ante incidentes.



Fases del plan

**1**

Identificar

Activos críticos: Debian, WordPress, MariaDB, Apache, FTP, SSH y archivos sensibles.

**2**

Proteger

Contraseñas robustas, mínimo privilegio, hardening, copias de seguridad y reducción de superficie de ataque.

**3**

Detectar

Centralización de logs y alertas ante accesos sospechosos, cambios en archivos y modificaciones de permisos.

**4**

Responder

Aislar el servidor, detener servicios afectados, preservar evidencias, bloquear IPs maliciosas y corregir configuraciones.

**5**

Recuperar

Restaurar servicios de forma segura, validar las correcciones y comprobar que no quedan puertas traseras ni credenciales comprometidas.



Objetivo: establecer un procedimiento claro para prevenir, detectar, responder y recuperar el servicio ante futuros incidentes.

10 Monitorización y Wazuh



Objetivo

Detectar, alertar y responder de forma temprana ante actividades sospechosas o maliciosas en el servidor comprometido.

Wazuh implementado



Agente instalado en el servidor Debian

Monitorización de logs, autenticación e integridad de archivos.



Envío de eventos al gestor Wazuh

Centralización y análisis en tiempo real.



Reglas de detección activas

Detección de accesos fallidos, cambios críticos y actividad sospechosa.



Alertas en tiempo real

Notificaciones para eventos críticos con umbrales definidos.

EVENTOS TOTALES

15.784

↑ 18% vs. ayer



NIVELES DE ALERTA



FUENTES DE EVENTOS



ALERTAS RECIENTES

	10:24:31	Crítico	Múltiples fallos de autenticación SSH desde 185.199.108.153	sshd
	10:18:07	Alto	Cambio detectado en wp-config.php	syscheck
	10:12:44	Alto	Creación de usuario: nuevo_admin	syscheck
	10:08:19	Medio	Modificación de permisos en /var/www	syscheck
	10:03:55	Bajo	Servicio Apache reiniciado	apache

[Ver todas las alertas](#) →

ORIGEN DE ACTIVIDAD / ATAQUES



Eventos a monitorizar

- 1 Accesos SSH y fallos de autenticación
- 2 Cambios en archivos críticos como wp-config.php
- 3 Modificación de permisos y creación de usuarios
- 4 Actividad en Apache, FTP y WordPress
- 5 Alertas de fuerza bruta y eventos del sistema



Resultado: mayor visibilidad del entorno, detección temprana de amenazas y mejor capacidad de respuesta ante incidentes.

Objetivo

Fortalecer la postura de seguridad del sistema y reducir la superficie de ataque de forma continua.



1



Gestión segura de accesos

- Revisar usuarios y privilegios.
- Mantener mínimo privilegio y MFA cuando sea posible.

2



Contraseñas robustas

- Usar credenciales únicas y no reutilizadas.
- Cambiar contraseñas débiles o comprometidas.

3



Reducir la superficie de exposición

- Mantener activos solo los servicios necesarios.
- Sustituir FTP por SFTP o restringir su uso.

4



Actualización y hardening

- Mantener Debian, WordPress y paquetes actualizados.
- Revisar permisos, Apache, SSH y configuraciones críticas.

5



Monitorización continua

- Mantener Wazuh activo y revisar alertas.
- Vigilar accesos, cambios de archivos y eventos críticos.

6



Copias de seguridad y recuperación

- Realizar copias periódicas y probadas.
- Asegurar recuperación rápida del servicio.



Impacto esperado: menor superficie de ataque, mejor protección de credenciales, mayor capacidad de detección y mejor preparación ante incidentes futuros.





1. El incidente permitió identificar accesos inseguros, credenciales débiles y configuraciones vulnerables.



2. Las correcciones aplicadas redujeron la superficie de ataque del servidor Debian y reforzaron su protección.



3. La monitorización con Wazuh y el plan de respuesta mejoran la detección, la respuesta y la prevención futura.



La seguridad no es un estado final: es un proceso continuo de **revisión, detección y mejora.**